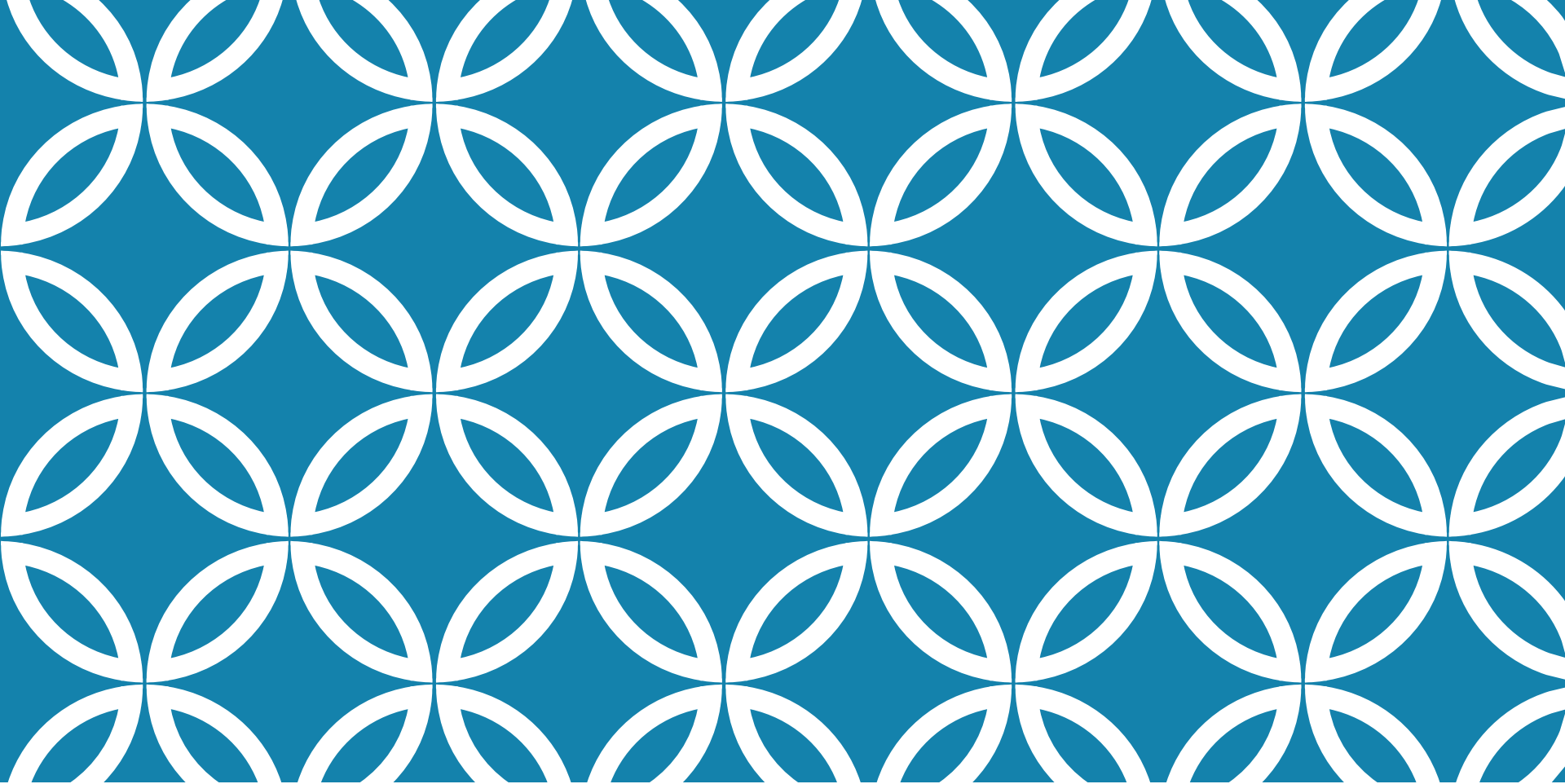




**GAINING ACCESS
... POSSIBLE WAYS**

ACCESS CONTROL

Two parts to access control

Authentication: Who goes there?

- Determine whether access is allowed
- Authenticate human to machine
- Authenticate machine to machine

Authorization: Are you allowed to do that?

- Once you have access, what can you do?
- Enforces limits on actions

Note: Access control often used as synonym for authorization



AUTHENTICATION

WHO GOES THERE?

How to authenticate a human to a machine?

Can be based on...

- Something you **know**
 - For example, a password
- Something you **have**
 - For example, a smartcard
- Something you **are**
 - For example, your fingerprint

SOMETHING YOU KNOW

Passwords

Lots of things act as passwords!

- PIN
- Social security number
- Mother's maiden name
- Date of birth
- Name of your pet, etc.

TROUBLE WITH PASSWORDS

“Passwords are one of the biggest practical problems facing security engineers today.”

“Passwords are the first line of defense against cyber criminals”

WHY PASSWORDS?

Why is “something you know” more popular than “something you have” and “something you are”?

Cost: passwords are free

Convenience: easier for admin to reset pwd than to issue user a new thumb

KEYS VS PASSWORDS

Crypto keys

Suppose a key is 64 bits long

Then 2^{64} keys

Choose key at random

Then attacker must try about 2^{63} keys

Passwords

Suppose passwords are 8 characters long, and 256 different characters

Then $256^8 = 2^{64}$ passwords

Users do **not** select passwords at random

Attacker has far less than 2^{63} passwords to try (**dictionary attack**)

GOOD AND BAD PASSWORDS

Bad passwords

- frank
- Fido
- password
- 4444
- Pikachu
- 102560
- AustinStamp

Good Passwords?

- jflej,43j-EmmL+y
- 09864376537263
- P0kem0N
- FSa7Yago
- OnceuP0nAt1m8
- PokeGCTall150

PASSWORD EXPERIMENT



Three groups of users — each group advised to select passwords as follows

- **Group A:** At least 6 chars, 1 non-letter
- **Group B:** Password based on passphrase
- **Group C:** 8 random characters

winner →

Results

- **Group A:** About 30% of pwds easy to crack
- **Group B:** About 10% cracked
 - Passwords easy to remember
- **Group C:** About 10% cracked
 - Passwords hard to remember

ATTACKS ON PASSWORDS

Attacker could...

- Target one particular account
- Target any account on system
- Target any account on any system
- Attempt denial of service (DoS) attack

Common attack path

- Outsider → normal user → administrator
- May only require **one** weak password!

WORST PASSWORDS RANKING (2025)

Classement ⓘ	Mot de passe ⓘ	Nombre ⓘ
1	123456	21 627 656
2	admin	21 030 012
3	12345678	8 274 408
4	123456789	5 673 712
5	12345	3 950 777
6	password	3 545 119

<https://nordpass.com/fr/most-common-passwords-list/>

PASSWORD FILE

Bad idea to store passwords in a file

But need a way to verify passwords

Cryptographic solution: **hash** the passwords

- Store $y = h(\text{password})$
- Can verify entered password by hashing
- If attacker obtains password file, he does not obtain passwords
- But attacker with password file can guess x and check whether $y = h(x)$
- If so, attacker has found password!

DICTIONARY ATTACK

Attacker pre-computes $h(x)$ for all x in a **dictionary** of common passwords

Suppose attacker gets access to password file containing hashed passwords

- Attacker only needs to compare hashes to his pre-computed dictionary
- Same attack will work each time

Can we prevent this attack?

Or at least make attacker's job more difficult?

PASSWORD FILE

Store hashed passwords

Better to hash with **salt**

Given password, choose random s , compute

$$y = h(\text{password}, s)$$

and store the pair (s, y) in the password file

Note: The salt s is **not secret**

Easy to verify password

Attacker must recompute dictionary hashes for each user
— lots more work!

OTHER PASSWORD ISSUES

Too many passwords to remember

- Results in password reuse
- Why is this a problem?

Who suffers from bad password?

- Login password vs ATM PIN

Failure to change default passwords

Social engineering

Error logs may contain “almost” passwords

Bugs, keystroke logging, spyware, etc.

PASSWORDS

The bottom line

Password cracking is too easy!

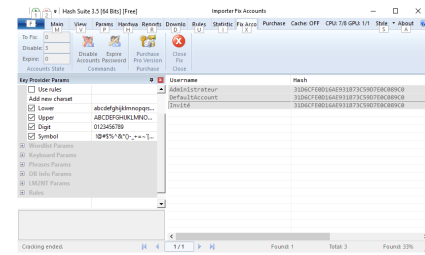
- One weak password may break security
- Users choose bad passwords
- Social engineering attacks, etc.

The bad guy has all of the advantages

All of the math favors bad guys

Passwords are a **big** security problem

PASSWORD CRACKING TOOLS



Popular password cracking tools

- L0phtCrack (Windows) - <https://www.l0phtcrack.com>
- John the Ripper (Unix) - <https://www.openwall.com/john> and HashSuite (Windows) - <https://hashsuite.openwall.net>
- Mimikatz (Windows) - <https://blog.gentilkiwi.com/mimikatz>

Admins should use these tools to test for weak passwords since attackers will!

```
mimikatz 2.1.1 x64 (oe.eo)

.#####. mimikatz 2.1.1 (x64) #17763 Dec  9 2018 23:56:50
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo) ** Kitten Edition **
## / \ ## /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #'  Vincent lEtOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ****

mimikatz # version

mimikatz 2.1.1 (arch x64)
Windows NT 10.0 build 17763 (arch x64)
msvc 150030729 207

> SecureKernel is running
> Credential Guard may be running

mimikatz #
```

BIOMETRICS



SOMETHING YOU ARE

Biometric

- “You are your key” — Schneier

□ Examples

- Fingerprint
- Handwritten signature
- Facial recognition
- Speech recognition
- Gait (walking) recognition
- “Digital doggie” (odor recognition)
- Many more!

WHY BIOMETRICS?

Biometrics seen as desirable replacement for passwords

Cheap and reliable biometrics needed

Today, a very active area of research

Biometrics are used in security today

- Thumbprint mouse
- Palm print for secure entry
- Fingerprint to unlock car door, etc.

But biometrics not too popular

- Has not lived up to its promise (yet)

IDEAL BIOMETRIC

Universal — applies to (almost) everyone

- In reality, no biometric applies to everyone

Distinguishing — distinguish with certainty

- In reality, cannot hope for 100% certainty

Permanent — physical characteristic being measured never changes

- In reality, want it to remain valid for a long time

Collectable — easy to collect required data

- Depends on whether subjects are cooperative

Safe, easy to use, etc., etc.

BIOMETRIC MODES

Identification — Who goes there?

- Compare one to many
- Example: The FBI fingerprint database

Authentication — Is that really you?

- Compare one to one
- Example: Thumbprint

Identification problem more difficult

- More “random” matches since more comparisons

We are interested in authentication

ENROLLMENT VS RECOGNITION

Enrollment phase

- Subject's biometric info put into database
- Must carefully measure the required info
- OK if slow and repeated measurement needed
- Must be very precise for good recognition
- A weak point of many biometric schemes

Recognition phase

- Biometric detection when used in practice
- Must be quick and simple
- But must be reasonably accurate

FINGERPRINT HISTORY

1888 — Sir Francis Galton (cousin of Darwin) developed classification system

- His system of “minutia” is still in use today
- Also verified that fingerprints do not change

Some countries require a number of points (i.e., minutia) to match in criminal cases

- In Britain, 15 points
- In US, no fixed number of points required

FINGERPRINT BIOMETRIC

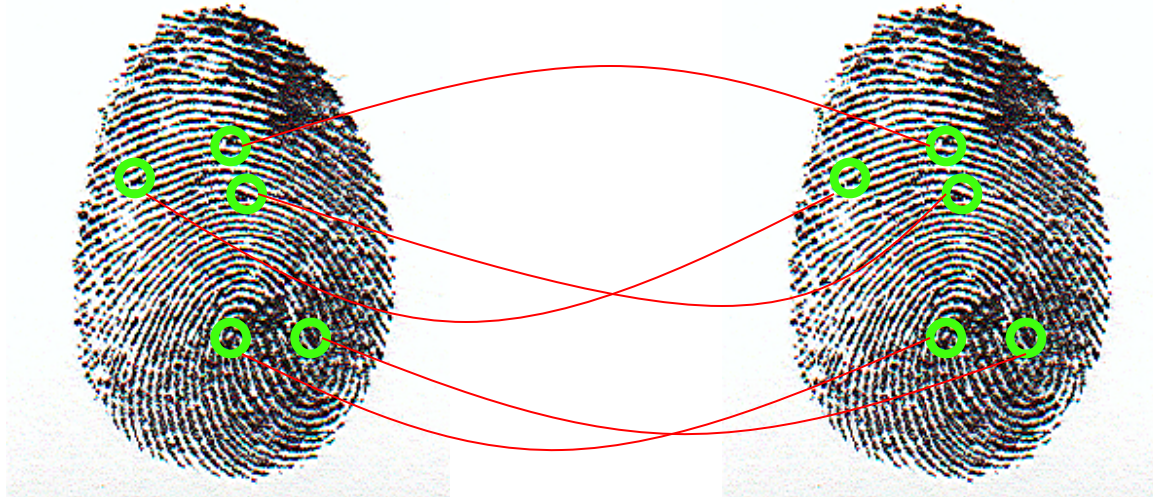


Capture image of fingerprint

Enhance image

Identify minutia

FINGERPRINT BIOMETRIC



Extracted minutia are compared with user's minutia stored in a database

Is it a statistical match?

HAND GEOMETRY

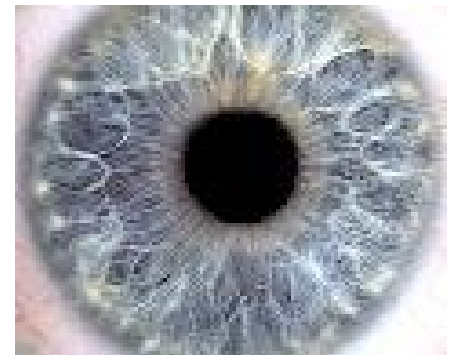
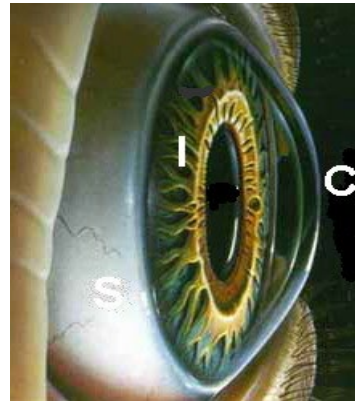
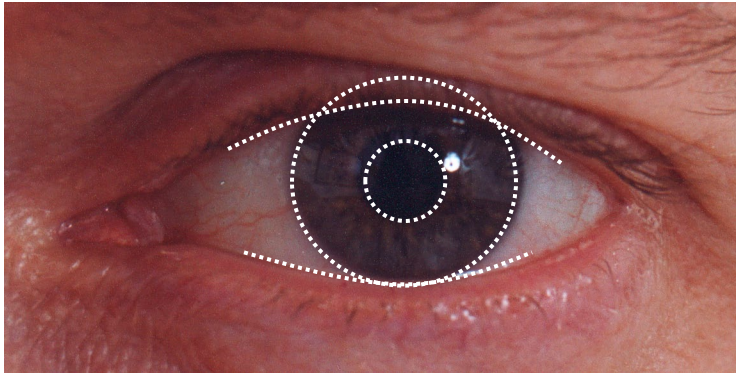
Advantages

- Quick
- 1 minute for enrollment
- 5 seconds for recognition
- Hands symmetric (use other hand backwards)

Disadvantages

- Cannot use on very young or very old
- Relatively high equal error rate

IRIS PATTERNS



Iris pattern development is “chaotic”

Little or no genetic influence

Different even for identical twins

Pattern is stable through lifetime

ATTACK ON IRIS SCAN

Good **photo** of eye can be scanned

- Attacker could use photo of eye

To prevent photo attack, scanner could use light to be sure it is a “live” iris



<https://thehackernews.com/2015/03/iris-biometric-security-bypass.html>

BIOMETRICS: THE BOTTOM LINE

Biometrics are hard to forge

But attacker could

- Steal Alice's thumb
- Photocopy Bob's fingerprint, eye, etc.
- Subvert software, database, "trusted path", ...

Also, how to revoke a "broken" biometric?

Biometrics are not foolproof!

Biometric use is limited today

That should change in the future...

SOMETHING YOU HAVE

Something in your possession

Examples include

- Car key
- Laptop computer
 - Or specific MAC address
- Password generator
- ATM card, smartcard, etc.

2-FACTOR AUTHENTICATION

Requires 2 out of 3 of

1. Something you know
2. Something you have
3. Something you are

Examples

- ATM: Card and PIN
- Credit card: Card and signature
- Password generator: Device and PIN
- Smartcard with password/PIN

SINGLE SIGN-ON

A hassle to enter password(s) repeatedly

- Users want to authenticate only once
- “Credentials” stay with user wherever he goes
- Subsequent authentication is transparent to user

WEB COOKIES

Cookie is provided by a Website and stored on user's machine

Cookie indexes a database at Website

Cookies **maintain state** across sessions

Web uses a stateless protocol: HTTP

Cookies also maintain state within a session

Like a single sign-on for a website

- Though a very weak form of authentication

Cookies and privacy concerns



AUTHORIZATION

AUTHENTICATION VS AUTHORIZATION

Authentication — Who goes there?

- Restrictions on who (or what) can access system

Authorization — Are you allowed to do that?

- Restrictions on actions of authenticated users

Authorization is a form of **access control**

Authorization enforced by

- Access Control Lists
- Capabilities

LAMPSON'S ACCESS CONTROL MATRIX

Subjects (users) index the rows

Objects (resources) index the columns

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwX	rwX	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

ARE YOU ALLOWED TO DO THAT?

Access control matrix has all relevant info

But how to manage a large access control (AC) matrix?

Need to check this matrix before access to any resource is allowed

Hopelessly inefficient

INFERENCE CONTROL EXAMPLE

Suppose we query a database

- Question: What is average salary of female CS professors at UT?
- Answer: about 50,000 €
- Question: How many female CS professors at UT?
- Answer: 1

Specific information has leaked from responses to general questions!

INFERENCE CONTROL AND RESEARCH

For example, medical records are private but valuable for research

How to make info available for research and protect privacy?

How to allow access to such data without leaking specific information?

NAÏVE INFERENCE CONTROL

Remove names from medical records?

Still may be easy to get specific info from such “anonymous” data

Removing names is not enough

- As seen in previous example

What more can be done?

LESS-NAÏVE INFERENCE CONTROL

Query set size control

- Don't return an answer if set size is too small

N-respondent, $k\%$ dominance rule

- Do not release statistic if $k\%$ or more contributed by N or fewer

Randomization

- Add small amount of random noise to data

Many other methods — none satisfactory

INFERENCE CONTROL: THE BOTTOM LINE

Robust inference control may be impossible

Is weak inference control better than no inference control?

- **Yes:** Reduces amount of information that leaks and thereby limits the damage

Is weak crypto better than no crypto?

- **Probably not:** Encryption indicates important data
- May be easier to filter encrypted data

CAPTCHA

☐

I'm not a robot


ReCAPTCHA

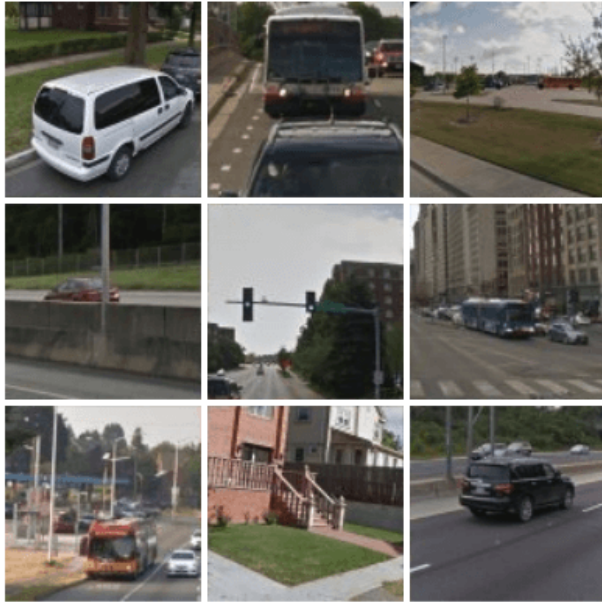


type the two words:




reCAPTCHA™
stop spam.
read books.

Select all images with a
bus
Click verify once there are none left.





VERIFY

TURING TEST

Proposed by Alan Turing in 1950

Human asks questions to one other human and one computer (without seeing either)

If human questioner cannot distinguish the human from the computer responder, the computer passes the test

The gold standard in artificial intelligence

No computer can pass this today

CAPTCHA

CAPTCHA — **C**ompletely **A**utomated **P**ublic **T**uring test to tell **C**omputers and **H**umans **A**part

Automated — test is generated and scored by a computer program

Public — program and data are public

Turing test to tell... — humans can pass the test, but machines cannot pass the test

Like an inverse Turing test (sort of...)

CAPTCHA PARADOX

“...CAPTCHA is a program that can generate and grade tests that it itself cannot pass...”

“...much like some professors...”

Paradox — computer creates and scores test that it cannot pass!

CAPTCHA used to restrict access to resources to humans (no computers)

CAPTCHA useful for **access control**

CAPTCHA: RULES OF THE GAME

Must be easy for most humans to pass

Must be difficult or impossible for machines to pass

- Even with access to CAPTCHA software

The only unknown is some random number

Desirable to have different CAPTCHAs in case some person cannot pass one type

- Blind person could not pass visual test, etc.

DO CAPTCHAS EXIST?

Test: Find 2 words in the following



- Easy (hum ...) for most humans
- Difficult for computers (OCR problem)

CAPTCHAS

Current types of CAPTCHAs

- Visual
 - Like previous example
 - Many others
- Audio
 - Distorted words or music

No text-based CAPTCHAs

- Maybe this is not possible...

CAPTCHA'S AND AI

Computer recognition of distorted text is a challenging AI problem

- But humans can solve this problem

Same is true of distorted sound

- Humans also good at solving this

Hackers who break such a CAPTCHA have solved a hard AI problem

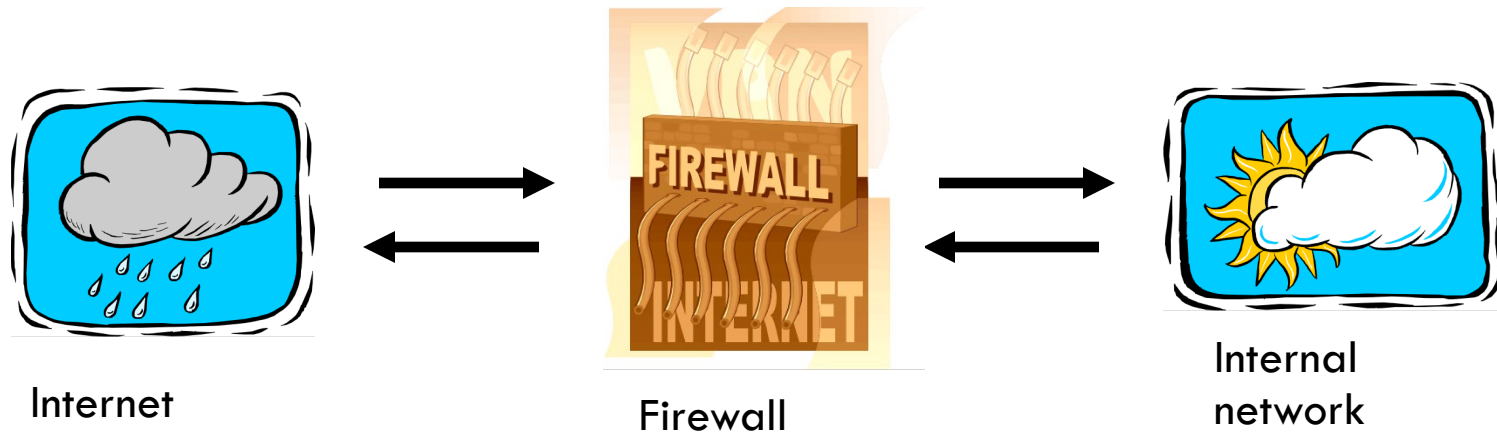
Putting hacker's effort to good use!

May be other ways to defeat CAPTCHAs...

FIREWALLS



FIREWALLS



Firewall must determine what to let in to internal network and/or what to let out

Access control for the network

FIREWALL AS SECRETARY

A firewall is like a **secretary**

To meet with an executive

- First contact the secretary
- Secretary decides if meeting is reasonable
- Secretary filters out many requests

You want to meet chair of CS department?

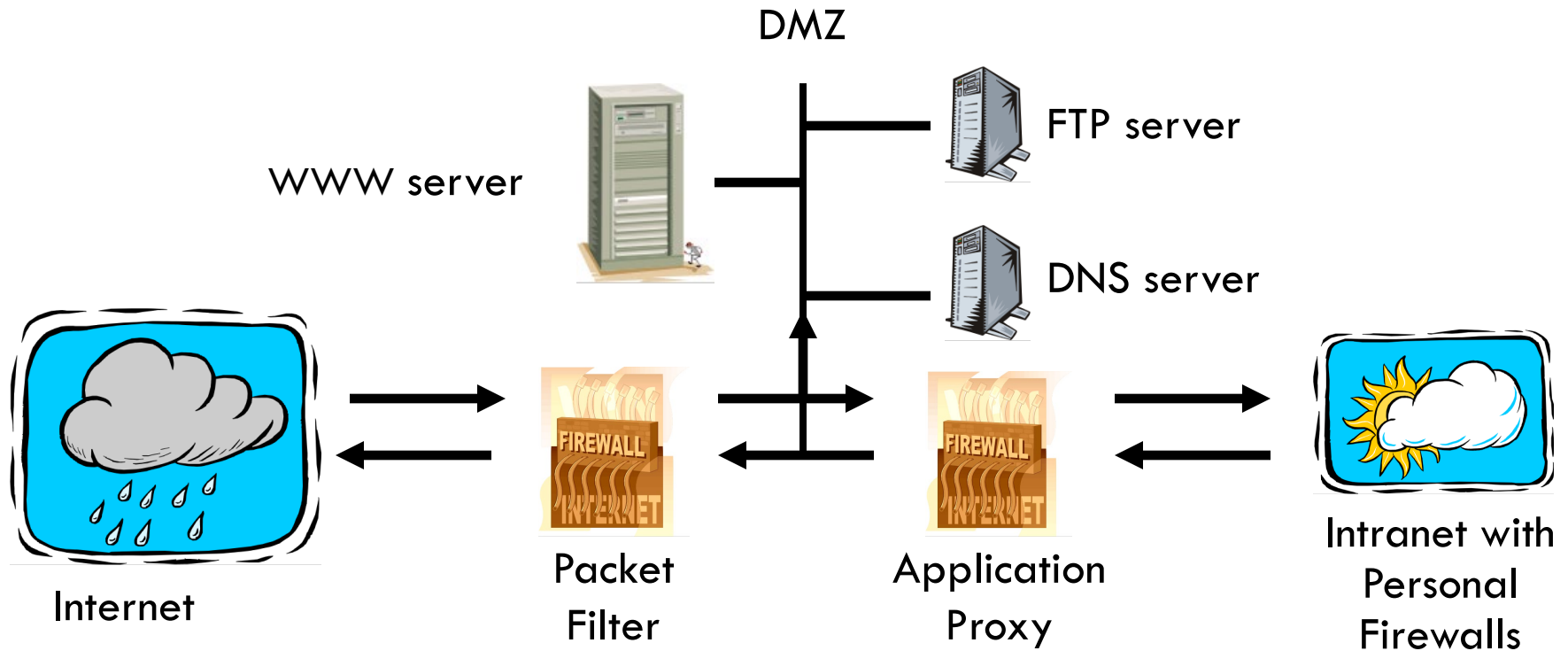
- Secretary does some filtering

You want to meet President Macron?

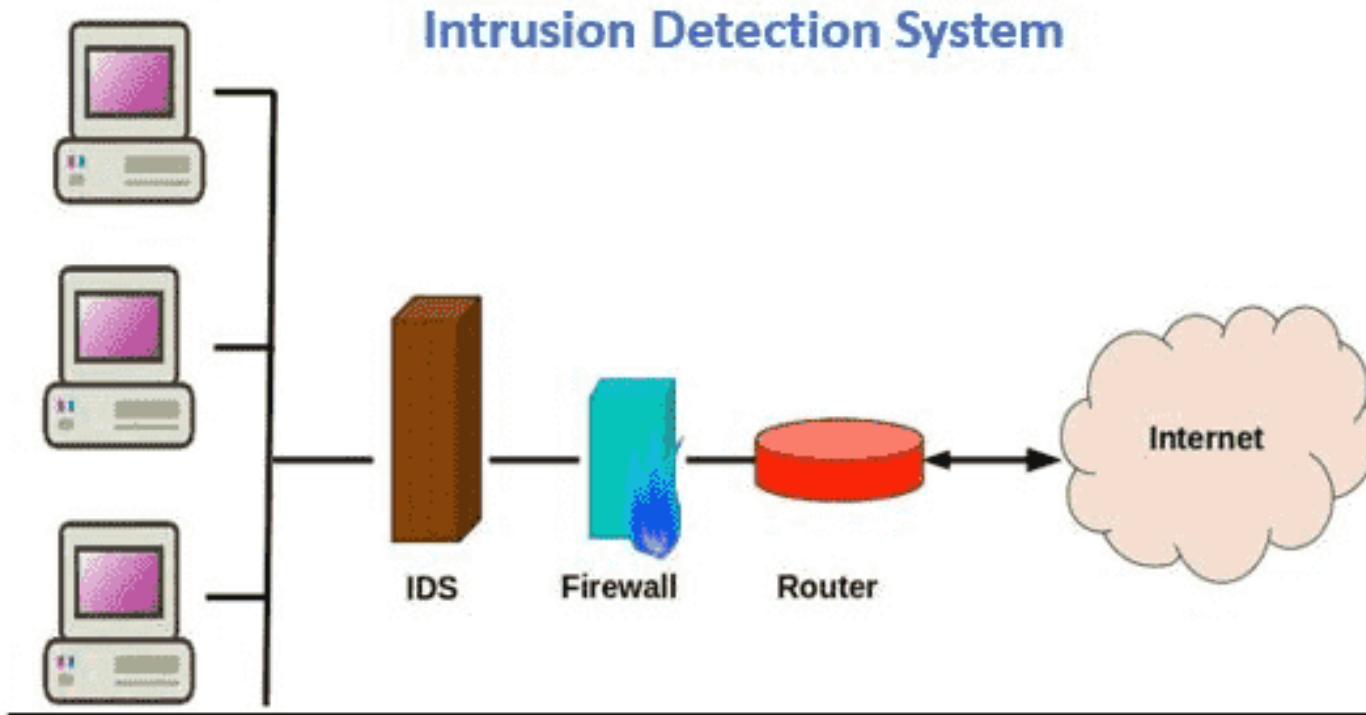
- Secretary does lots of filtering!

FIREWALLS AND DEFENSE IN DEPTH

Example security architecture



INTRUSION DETECTION SYSTEMS



INTRUSION PREVENTION

Want to keep bad guys out

Intrusion prevention is a traditional focus of computer security

- Authentication is to prevent intrusions
- Firewalls a form of intrusion prevention
- Virus defenses also intrusion prevention

Comparable to locking the door on your car

INTRUSION DETECTION

In spite of intrusion prevention, bad guys will sometime get into system

Intrusion detection systems (IDS)

- Detect attacks
- Look for “unusual” activity

IDS developed out of log file analysis

IDS is currently a very **hot** research topic

How to respond when intrusion detected?

- We don't deal with this topic here

INTRUSION DETECTION SYSTEMS

Who is likely intruder?

- May be outsider who got through firewall
- May be evil insider

What do intruders do?

- Launch well-known attacks
- Launch variations on well-known attacks
- Launch new or little-known attacks
- Use a system to attack other systems
- Etc.

ANOMALY DETECTION

Anomaly detection systems look for unusual or abnormal behavior

There are (at least) two challenges

- What is normal for this system?
- How “far” from normal is abnormal?

Statistics is obviously required here!

- The **mean** defines normal
- The **variance** indicates how far abnormal lives from normal

HOW TO MEASURE NORMAL?

How to measure normal?

- Must measure during “representative” behavior
- Must not measure during an attack...
- ...or else attack will seem normal!
- Normal is statistical mean
- Must also compute variance to have any reasonable chance of success

HOW TO MEASURE ABNORMAL?

Abnormal is relative to some “normal”

- Abnormal indicates possible attack

Statistical discrimination techniques:

- Bayesian statistics
- Neural nets, hidden Markov models, etc.
- ...

Fancy modeling techniques also used

- Artificial intelligence
- Artificial immune system principles
- Many others!